

Multi-Party Authorization Proxy

Progress Update 3 — CS 6727 Practicum

Ian Barish

AI use: Deck drafted with AI assistance — all design and project decisions are my own.

The Project So Far

A proxy that requires **multiple approvers** to sign off before a sensitive action runs — its headline case is publishing a package to PyPI.

- Researched the problem: one compromised maintainer can ship to everyone
- Wrote the full design — specifications, ADRs, and a threat model
- Renamed the project from "Multi-Signature" to "Multi-Party"

Completed Tasks

Shifted from writing specs to building — the MVP now runs end-to-end with roughly 12,700 lines of code and tests and 29 reviewed pull requests this cycle.

- **Intercept:** uploads are held and bound to a SHA-256 hash
- **Approve:** a quorum of signed votes in an append-only log
- **Publish:** the hash is re-verified, then forwarded to PyPI
- **Around it:** email alerts, an audit trail, portals, Docker

Next Steps

Threat model

Finish it and map every threat to an industry framework

Evaluation suite

Build it from the threats and user stories

Results & outline

Run the suite, gather results, start the report

Feedback Request

BACKGROUND

My final result is a **security score** — I grade the proxy against a list of threats. But I wrote that threat list myself, so the score grades its own homework.

Should I anchor it to a public framework — **MITRE ATT&CK**, or supply-chain-specific **SLSA / CNCF Catalog** — and does that actually close the blind-spot?